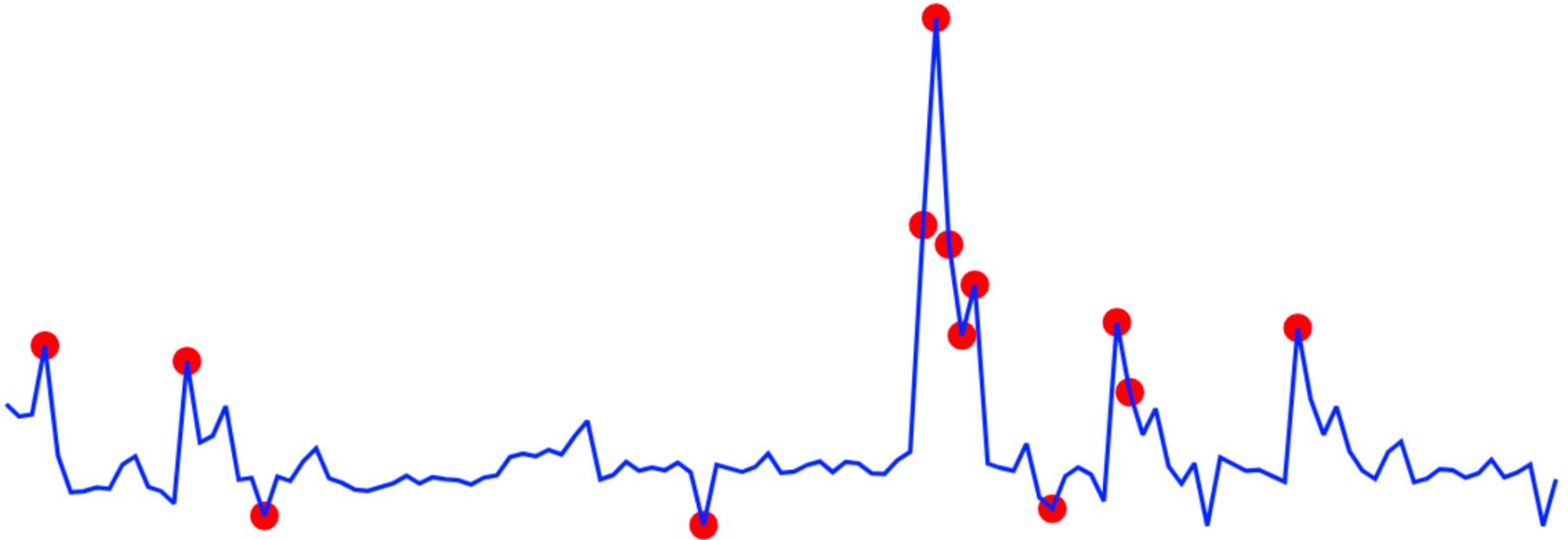


Basslines and Baselines:

The Role of Anomaly Detection in Cloud Security

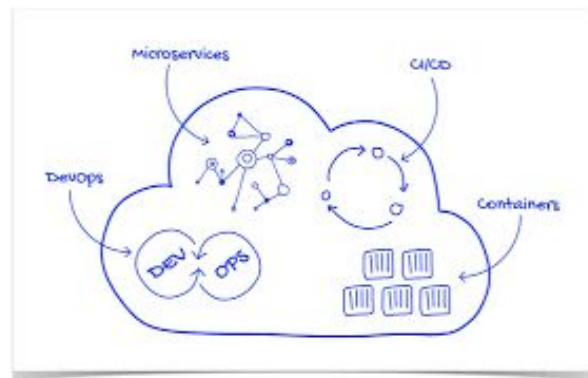


Introduction

- Why anomaly detection for cloud security? Why now?
- Understanding anomaly-based detection
 - i. History and original motivation
 - ii. Model components
- The promise of anomaly detection
- The practical challenges of anomaly detection
- Challenging the anomaly detection paradigm
- The evolution of anomaly detection

Why anomaly detection for cloud security? Why now?

1. Cloud security is a growing challenge
 - a. More complex environments
 - b. More dynamic environments
 - i. More changes
 - ii. More ephemeral
 - c. Larger risk surface
 - d. [Researchers](#) found insecure configurations in 72 percent of the environments monitored from September 2021 to February 2022.
 - e. 2021 saw a [record breaking number](#) of zero day exploits found in-the-wild, according to Google's Project Zero team



Why anomaly detection for cloud security? Why now?

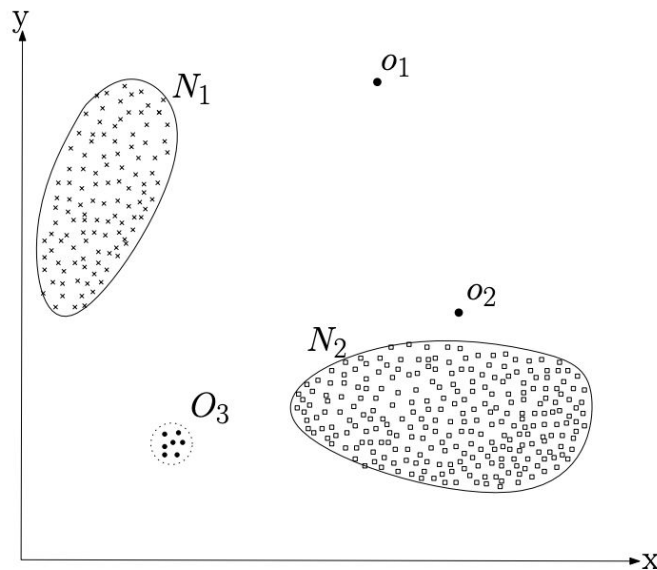
Signature-based approaches alone aren't sufficient

- i.* Rules and policies (and thresholds) frequently fall short as security analysts tether an edge between being too restrictive and too permissive.
- ii.* Tighten rules too much and you're flooded with false positives and alert storms. Add too many exceptions and gaps are opened.
- iii.* Constant human intervention is required, drawing precious time away from analysts and engineers, who inevitably will get it wrong at times in a high-entropy, cloud native environment.
- iv.* While signature-based solutions are the most commercially employed approach, they cannot detect novel attacks (zero day) and unknown variants of existing attacks, and can [often fail against even the simplest obfuscation techniques](#).

What are anomalies?

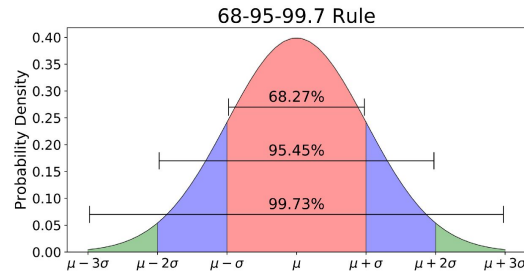
1. Anomalies are different from the norm with respect to their features.
2. They are rare in a dataset compared to normal instances.

Goldstein, Uchida (2016)



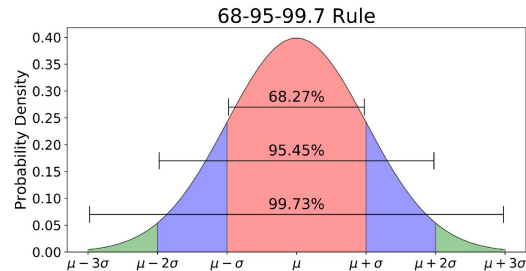
The history of anomaly detection IDS

“The model is based on the hypothesis that exploitation of a system's vulnerabilities involves abnormal use, of the system; therefore, security violations could be detected from abnormal patterns of system usage.”



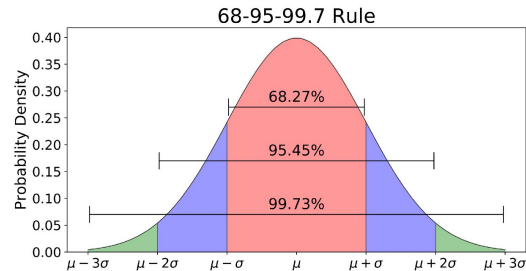
The history of anomaly detection IDS

“The model is independent of any particular system, application environment, system vulnerability, or type of intrusion, thereby providing a framework for a general-purpose intrusion-detection expert system.”



The history of anomaly detection IDS

“[...] an extra layer of protection that enhances the overall security of the target system”



The history of anomaly detection IDS

“The development of a real-time intrusion-detection system is motivated by four factors:

1) most existing systems have security flaws that render them susceptible to intrusions, penetrations, and other forms of abuse;
finding and fixing all these deficiencies is not feasible for technical and economic reasons;

“An Intrusion-Detection Model” Denning (1987)



The history of anomaly detection IDS

2) existing systems with known flaws are **not easily replaced** by systems that are more secure-mainly because the systems have attractive features that are missing in the more secure systems, or else they cannot be replaced for economic reasons;

“An Intrusion-Detection Model” Denning (1987)



The history of anomaly detection IDS

3) **developing systems** that are absolutely secure is extremely difficult, if not generally impossible; and

"An Intrusion-Detection Model" Denning (1987)



The history of anomaly detection IDS

4) even the most secure systems are vulnerable to abuses by **insiders** who misuse their privileges.”

“An Intrusion-Detection Model” Denning (1987)



Anomaly detection model

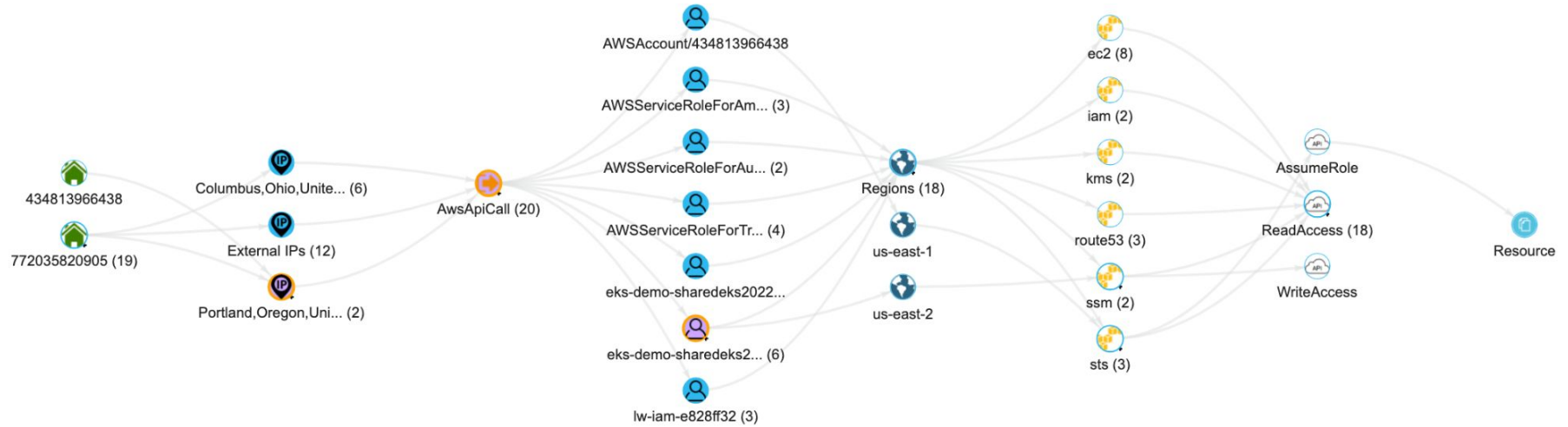
The model has six main components:

- **Subjects**: Initiators of activity on a target system- normally users.
- **Objects**: Resources managed by the system-files, commands, devices, etc.
- **Audit records**: Generated by the target system in response to actions performed or attempted by subjects on objects-user login, command execution, file access, etc.
- **Profiles**: Structures that characterize the behavior of subjects with respect to objects in terms of statistical metrics and models of observed activity. Profiles are automatically generated and initialized from templates.
- **Anomaly records**: Generated when abnormal behavior is detected.
- **Activity rules**: Actions taken when some condition is satisfied, which update profiles, detect abnormal behavior, relate anomalies to suspected intrusions, and produce reports.

Think of securing a house



Think of securing a house



Baseline:

[The bass part is] the groundwork or foundation upon which all musical composition is to be erected.

— Christopher Simpson 1667



Groove:

"an unspecifiable but ordered sense of something that is sustained in a distinctive, regular and attractive way, working to draw the listener in."

"feel created by a repeating framework" is also modified with **variations**.

The promise of anomaly detection

- It can detect insider threats. For example, if someone gets a hold of legitimate user credentials (masquerade attack) , anomalous behavior could be detected and prevent misuse.
- It can detect previously unknown attack vectors (i.e. zero day attacks), as anomaly detection techniques do not rely on known signatures, such as known CVEs or security benchmark checklists.

The promise of anomaly detection

- It presents a formidable barrier to malicious actors, as hackers cannot simply circumvent known (or expected) security measures, and instead must contend with the fact that they are operating in an environment where potentially any of their steps will get flagged as anomalous and alerted.
- Reduce false-positives and false-negatives, reduce alert fatigue
- Reduce or eliminate alert storms, by creating a logical model

Challenging the Anomaly Detection Paradigm

The primary assumptions that are made regarding the problem domain are:

- attacks are anomalous (different from the norm),
 - “Hide your tracks”
- attacks are rare, and
 - “Hide in the crowd”
- anomalous activity is malicious
 - “Constant change”

Gates, Taylor (2009)

<https://www.nspw.org/2009/proceedings/2006/nspw2006-gates.pdf>

The practical challenges of Anomaly Detection

- a. The anomaly detection techniques need to be computationally efficient in order to handle cloud scale sized inputs.
- b. Fast and scalable
- c. Streaming data requires online analysis
- d. *Big Data and the “curse of dimensionality”*
 - i. The curse of dimensionality affects anomaly detection techniques because the events we care about, significant anomalies, can be obscured or even concealed by unnecessary attributes or missing data.

The practical challenges of Anomaly Detection

a. Rich domain knowledge is needed

- i.* It's not enough to have excellent data science and algorithms—the data needs to be processed and contextualized with deep expertise in both the cloud and the security domains.
- ii.* Modern cloud native services can encompass quite a varied set of building blocks, VMs (e.g., EC2), different Kubernetes distributions, serverless frameworks, and an ever growing variety of cloud APIs. All of this needs to be considered to properly identify and protect organizations from real threats.

The practical challenges of Anomaly Detection

a. Development velocity

- i.* Mature CI/CD practices enable developers and product teams to release new features faster than ever. This is a marked difference from the way things were done in the past, where workloads frequently remained static for months or years.
- ii.* Cloud-native workloads also scale and change, sometimes even during a single day. The velocity of change requires more sophisticated algorithms and data models, along with the ability to continually observe and understand organization's environments and workflows.

The practical challenges of Anomaly Detection

a. Disparate data sources

- i.* In order to draw accurate insights about an organization's cloud environments, data has to be correlated across many different sources, like cloud API logs, network connections established, process activity, and files and containers scanned.
- ii.* If this data is found across multiple tools, or point-solutions, then it becomes difficult to process them continuously enough to generate timely insights, or to combine and correlate them to find abnormalities.

Breaking the Anomaly Detection Paradigm

- Recon of target
- More noise, less accuracy.
 - Covert channels.

Maynor (2011)

The evolution of anomaly detection

Using unsupervised machine learning to create a baseline

Supervised machine learning algorithms are trained with examples.

Unsupervised machine learning algorithms, on the other hand, learn what normal behavior is, and then apply a statistical technique to determine if a specific data point is an anomaly without the need for human intervention.

The evolution of anomaly detection

Scale and speed

While cloud native complexity increases, compute power and speed also increases so we can meet the challenge

“How scalable is your platform/tool?”

“How many resources can it handle?”

The evolution of anomaly detection

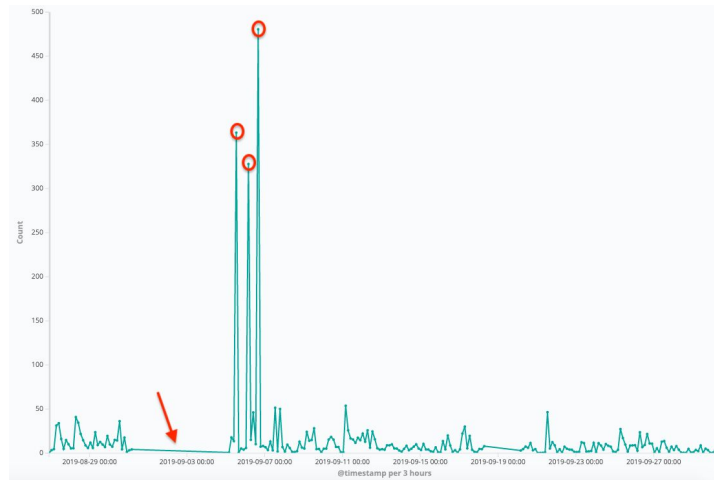
More mature models and research are available

Recent methods include: [Local Outlier Factor](#), and [Isolation Forest](#)

The most common techniques employed for anomaly detection are based on the construction of a profile of what is “normal”. Isolation Forest uses a different approach: **instead of trying to build a model of normal instances, it explicitly isolates anomalous points in the dataset.**

The main advantage of this approach is the possibility of exploiting [sampling](#) techniques to an extent that is not allowed to the profile-based methods, creating a **very fast algorithm with a low memory demand**

Fei Tony Liu, Kai Ming Ting and Zhi-Hua Zhou (2008)



“How good is your data science team?”
“What’s your data eng roadmap?”

The future of anomaly detection for cloud security

- a. *Better tools*
- b. *Combining signature-based + anomaly detection*
- c. *Better data models*
- d. *Correlation*
- e. *R&D*

Get into the groove



THANK YOU, RVA!

The evolution of anomaly detection

Adaptive Behavioral Profiles

Techniques to age out or lower severity of recurring events

The promise of anomaly detection

Attempted break-in: Someone attempting to break into a system might generate an abnormally high rate of password failures with respect to a single account or the system as a whole.

- Masquerading or successful break-in: Someone logging into a system through an unauthorized account and password might have a different login time, location, or connection type from that of the account's legitimate user. In addition, the penetrator's behavior may differ considerably from that of the legitimate, user-, in particular, he might spend most of his time browsing through directories and executing system status commands, whereas the legitimate user might concentrate on editing or compiling and linking programs. Many break-ins have been discovered by security officers or other users on the system who have noticed the alleged user behaving strangely.
- Penetration by legitimate user: A user attempting to penetrate the security mechanisms in the operating system might execute different programs or trigger more protection violations from attempts to access unauthorized files or programs. If his attempt succeeds, he will have access to commands and files not normally permitted to him.
- Leakage by legitimate user: A user trying to leak sensitive documents might log into the system at unusual times or route data to remote printers not normally used.

The promise of anomaly detection

- Inference by legitimate user: A user attempting to obtain unauthorized data from a database through aggregation and inference might retrieve more records than usual.
- Trojan horse: The behavior of a Trojan horse planted in or substituted for a program may differ from the legitimate program in terms of its CPU time or I/O activity.
- Virus: A virus planted in a system might cause an increase in the frequency of executable files rewritten, storage used by executable files, or a particular program being executed as the virus spreads.
- Denial-of-Service: An intruder able to monopolize a resource (e.g., network) might have abnormally high activity with respect to the resource, while activity for all other users is abnormally low.